

Q7

Prepare and present the breach analysis report

10 Marks

Objective: Combine the outputs of Q1–Q6 into a short, structured breach analysis report with findings, risk interpretation and lessons learned.

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Collect your completed tables from Q1–Q6.	Q1–Q6 outputs	All tables gathered
2	REPORT	Write an executive summary (3–4 sentences) of the breach.	Summary	Executive summary
3	REPORT	Add sections: background, CIA, kill chain, risk matrix, mitigations, CSF gaps.	Report structure	Draft report
4	ANALYSE	Write a lessons-learned section with 3–5 concrete takeaways.	—	Lessons learned
5	TEST	Proofread for clarity and check every claim traces to evidence.	Review checklist	Report reviewed
6	REPORT	Export the report and prepare a short presentation.	PDF / slides	Final deliverables

Phase key: ● SETUP · ● CONFIGURE · ● EXECUTE · ● TEST · ● ANALYSE · ● REPORT · ● FINISH

Worked Example (with sample values & output)

Report structure (Acme HealthCare)

Section	Content	Comes from
1. Executive Summary	3-4 sentence overview of the breach	New
2. Incident Background	Verified facts and timeline	Q2
3. Threat Classification	CIA impact of each action	Q1
4. Attack Mapping	Kill chain + ATT&CK techniques	Q3
5. Risk Assessment	Prioritised risk matrix	Q4
6. Recommended Mitigations	Preventive / detective / corrective	Q5
7. NIST CSF Gap Analysis	Function ratings and gaps	Q6
8. Lessons Learned	3-5 concrete, actionable takeaways	New

Sample lessons learned: deploy MFA on all accounts; add attachment sandboxing to email; monitor for large data exports; and test backups quarterly.

Reusable Template

Submission checklist

✓	Check before submitting
□	Executive summary present



✓	Check before submitting
☐	All six analysis tables (Q1-Q6) included
☐	Every claim backed by a source or table
☐	Lessons learned are specific and actionable
☐	Report + GitHub link uploaded to ZOSIMA

Your Output :

1. Executive Summary : In September 2024, a leading E-commerce Platform suffered a major data breach inspired by the real Magecart attack. Attackers injected malicious JavaScript into the checkout page, leading to the theft of over 50,000 customer PII and payment card records. The breach also involved ransomware on backup storage and admin account takeover due to missing MFA. This report combines Q1-Q6 findings to provide full analysis and mitigation as per NIST CSF.

2. Incident Background On 15th Aug 2024, the attacker exploited a SQL injection vulnerability in the third-party payment plugin of the E-commerce platform. The IT team detected fraudulent transactions reported by customers on 7th Sep 2024. Investigation revealed the attacker remained undetected for 22 days due to lack of SIEM monitoring. The attack timeline was: Initial Access via SQLi -> Data Exfiltration via large customer data export -> Ransomware deployment on S3 backups -> Admin account takeover. The incident was confirmed after backup files were found encrypted and deleted.

3. Threat Classification (CIA Triad Impact)

- **Data Theft (Customer DB):** High impact on Confidentiality - Customer PII, emails and card data were stolen. Impact on Integrity - Low, Availability - Low.
- **Ransomware (Backup Storage):** High impact on Availability - Backups encrypted and deleted. High impact on Integrity - Backup data tampered. Impact on Confidentiality - Low.
- **Account Takeover (Admin Panel):** High impact on Confidentiality, Integrity and Availability as attacker got full admin control due to weak password and no MFA.

4. Attack Mapping (Q3)

- **Reconnaissance:** T1595 - Active Scanning - Attacker scanned checkout page for vulnerabilities.
- **Weaponization & Delivery:** T1190 - Exploit Public-Facing Application (SQL Injection) and T1189 - Drive-by Compromise (Malicious JS injection in payment page).
- **Exploitation:** T1078 - Valid Accounts - Admin account compromised due to weak password.
- **Installation & C2:** T1505.003 - Web Shell installed on server and T1071 - Application Layer Protocol used for data exfiltration.
- **Actions on Objectives:** T1005 - Data from Local System (50k PII stolen) and T1486 - Data Encrypted for Impact (Ransomware on backups).

5. Risk Assessment (Q4)

Risk 1: Data Theft - Customer PII and Card Data Export



- Likelihood: High. Reason: No WAF, no SQL injection monitoring, and checkout page was vulnerable.
- Impact: Critical. Reason: 50,000 customer records including PII and payment data stolen, leads to GDPR fine and loss of trust.
- Overall Risk: Critical. Priority: Priority 1 - Fix immediately.

Risk 2: Ransomware - Backup Storage Encryption and Deletion

- Likelihood: Medium. Reason: S3 backup bucket was public and had no immutable lock, attacker easily found it.
- Impact: High. Reason: All backups encrypted and deleted, so business cannot recover data quickly, high downtime.
- Overall Risk: High. Priority: Priority 2.

Risk 3: Account Takeover - Admin Panel Access

- Likelihood: High. Reason: Admin used weak password and MFA was not enabled, so brute-force was easy.
- Impact: High. Reason: Attacker got full admin control which can lead to further data theft and persistence in system.
- Overall Risk: High. Priority: Priority 3.

6. Recommended Mitigations (Q5) - Three Lines of Defence

A) For Data Theft - Customer Database

- Preventive Control: Deploy WAF on all payment pages, use parameterized queries to prevent SQLi, and enforce tokenization for card data so raw card data is not stored.
- Detective Control: Create SIEM rule - Alert if SELECT * query returns >1000 records or if data is exported outside office hours. Also monitor for Magecart JS injection.
- Corrective Control: Isolate affected database, block attacker IP, inform customers and regulator within 72 hours as per GDPR, and restore clean data from immutable backup.

B) For Ransomware - Backup Storage

- Preventive Control: Make backup S3 bucket private, enable MFA Delete and enable S3 Object Lock with immutability for 90 days. Implement 3-2-1 backup rule.
- Detective Control: Enable CloudTrail logging and SIEM alert for high volume delete or encrypt API calls on backup bucket.
- Corrective Control: Disconnect infected system from network, restore data from immutable backup, and run full malware scan before going live.

C) For Account Takeover - Admin Panel

- Preventive Control: Enforce 12-character complex password policy and mandatory MFA for all admins. Implement principle of least privilege for admin access.
- Detective Control: SIEM detection for multiple failed login attempts, login from new location, and admin access at odd hours.
- Corrective Control: Reset all admin passwords immediately, revoke active sessions, and audit admin logs for last 30 days to find persistence

7. NIST CSF - Response and Recovery Plan (Q6)



Response Plan (RS)

- *RS.RP-1 - Response Plan Execution:* As soon as fraud reports came on 7th Sep, activate Incident Response Team. Isolate infected checkout page server and block attacker IP immediately to stop further theft.
- *RS.CO-1 - Communication:* Inform internal stakeholders (CEO, Legal, IT Head), notify affected 50,000 customers, and inform payment gateway and law enforcement. Maintain evidence chain for forensic team.
- *RS.AN-1 - Analysis:* Forensic team to analyze web server logs to confirm SQLi entry point, check how much data exfiltrated via T1071 technique, and confirm web shell location.
- *RS.MI-1 - Mitigation:* Remove malicious JavaScript from checkout page, patch SQL injection vulnerability with parameterized query, and disable compromised admin account.
- *RS.MA-1 - Documentation:* Document complete incident timeline, IOCs like attacker IP and malicious JS hash, and create formal incident report for management.

Recovery Plan (RC)

- *RC.RP-1 - Recovery Plan Execution:* Restore E-commerce platform and customer database from last known clean immutable S3 backup. Ensure backup is scanned for malware before restore.
- *RC.IM-1 - Improvements:* After recovery, enforce WAF, MFA for all admins, immutable backups, and conduct security awareness training for dev team on OWASP Top 10.
- *RC.CO-1 - Recovery Communication:* Inform customers and regulators that system is restored securely and what preventive steps are taken. Publish lessons learned document for future prevention.

8. Conclusion and Lessons Learned

The E-commerce breach of Aug-Sep 2024 was a critical Magecart-style attack where a single SQL injection vulnerability (T1190) allowed attackers to inject malicious JavaScript (T1189), steal 50,000+ customer PII and card data, encrypt backup storage (T1490), and take over admin panel (T1078) due to missing WAF, MFA, and SIEM monitoring. The attack remained undetected for 22 days, causing severe financial and reputational loss and violating GDPR.

Key lessons learned are specific and actionable: 1) Secure coding practice was missing - Action is to enforce parameterized queries and mandatory code review for all payment plugins within 7 days. 2) Authentication was weak - Action is to enforce 12-char password and mandatory MFA for all admins immediately. 3) Backup strategy failed - Action is to implement immutable backups with S3 Object Lock and 3-2-1 rule within 15 days. 4) Detection failed - Action is to deploy WAF and configure SIEM alerts for large data exports and backup deletion events and conduct security training.

Overall, implementing the proposed preventive, detective, and corrective controls as per NIST CSF will significantly improve the organization's security posture.

GitHub Repository : <https://github.com/Rishu188636/Ecommerce-Breach-Analysis>